

Políticas de Seguridad de la Información

Banco Ther S.A



UNIVERSIDAD
CATÓLICA
BOLIVIANA

Carrera: Ingeniería de Sistemas

Materia: Auditoría de Sistemas

Semestre: 9no Semestre

Integrantes:

García Aguirre Ignacio

Mattos Terán Fernanda

Pimentel Silva Jared

Quenta Ramos Ramiro

Valenzuela Rivera Mateo

Fecha: 06/04/2026

1 OBJETIVO

Establecer las directrices que seguirá el Banco Pyme Ther S.A. para la implementación y gestión del Sistema de Gestión de Seguridad de la Información, asegurando su alineación con los objetivos estratégicos institucionales, la estrategia de seguridad de la información y la normativa vigente emitida por la Autoridad de Supervisión del Sistema Financiero.

2 ALCANCE

El presente documento es de cumplimiento obligatorio para la Alta Gerencia, las unidades organizacionales, empleados, directivos y proveedores de servicios del Banco Pyme Ther S.A., según corresponda. Aplica a la Oficina Central en la ciudad de La Paz, donde se encuentra el Centro de Procesamiento de Datos (CPD) principal, así como a las sucursales del eje central y agencias regionales. Incluye todos los procesos estratégicos, operativos y de soporte tecnológico. Asimismo, comprende al Área de Tecnologías de Información y sus subgerencias: Infraestructura y Telecomunicaciones, Desarrollo de Sistemas, Aseguramiento de Calidad, Operaciones y Soporte, además de la Unidad de Administración de Datos. Todos los involucrados son responsables de su cumplimiento y correcta aplicación.

3 GLOSARIO DE TERMINOS

Termino	Significado
ASFI	Autoridad de Supervisión del Sistema Financiero de Bolivia.
SGSI	Sistema de Gestión de Seguridad de la Información, conjunto de políticas, procedimientos

	y controles para gestionar la seguridad de la información.
Core Bancario	Sistema central para la gestión de cuentas, créditos y operaciones financieras del banco.
CPD	Centro de Procesamiento de Datos, ubicado en la sede central de La Paz.
DRP	Plan de Recuperación ante Desastres (Disaster Recovery Plan).
EDR	Endpoint Detection and Response, herramienta de seguridad para detección y respuesta ante amenazas en endpoints.
MFA	Autenticación Multifactor, mecanismo que requiere dos o más factores de verificación para acceder a sistemas.
MAE	Máxima Autoridad Ejecutiva.
RTO	Recovery Time Objective, tiempo máximo aceptable para restaurar un sistema tras una interrupción.
RPO	Recovery Point Objective, antigüedad máxima aceptable de los datos recuperados tras una interrupción.
SAN	Storage Area Network, red de almacenamiento de alta velocidad.
VPN	Red Privada Virtual (Virtual Private Network), canal cifrado para comunicaciones seguras.
CID	Confidencialidad, Integridad y Disponibilidad, pilares de la seguridad de la información.

4 DOCUMENTOS INTERNOS RELACIONADOS

DESCRIPCIÓN	CÓDIGO
-------------	--------

Plan Estratégico Institucional 2026–2028	PEI-001
Plan Estratégico de Seguridad de la Información 2026–2028	PESI-001
Plan Estratégico de Tecnología de la Información 2026–2028	PETI-001
Organigrama Funcional del Área de Tecnologías de Información	ORG-TI-001
Inventario de Infraestructura de TI	INF-TI-001
Inventario de Software y Aplicaciones	INV-SW-001
Reglamento Interno de Trabajo	RIT-001
Plan de Recuperación ante Desastres (DRP)	DRP-001
Manuales de Funciones por Cargo (Área de TI)	MF-TI-001

5 DOCUMENTOS EXTERNOS RELACIONADOS

- **Estándar ISO/IEC 27001** – Sistema de Gestión de Seguridad de la Información.
- **Estándar ISO/IEC 27018** – Protección de datos personales en la nube.
- **PCI DSS v4.0** – Payment Card Industry Data Security Standard.
- **NIST CSF 2.0** – Marco de Ciberseguridad (NIST).
- **CIS Controls v8** – Controles técnicos de ciberseguridad.

- **OWASP Top 10 2021** – Riesgos críticos en aplicaciones web y móviles.
- **COBIT 2019** – Marco de gobierno y gestión de TI.
- **Normativa ASFI** – Autoridad de Supervisión del Sistema Financiero de Bolivia.

6 DIRECTRICES GENERALES

- 6.1 La información es un activo estratégico del Banco Pyme Ther S.A. Por ello, debe ser administrada y protegida en todo momento, sin importar el medio en el que se encuentre (físico, digital, en la nube o en el conocimiento del personal)
- 6.2 El banco implementará las medidas necesarias para proteger la confidencialidad, integridad y disponibilidad de la información, incorporando además criterios de confiabilidad, autenticidad, cumplimiento y no repudio, conforme a la normativa vigente de la ASFI.
- 6.3 Se asignarán los recursos necesarios para el desarrollo, implementación y mejora continua de la seguridad de la información, en línea con la estrategia institucional y el PEI 2026–2028.
- 6.4 El incumplimiento de estas políticas dará lugar a sanciones conforme al Reglamento Interno de Trabajo y la legislación boliviana vigente.
- 6.5 La Gerencia de Seguridad de la Información reporta directamente al Directorio, garantizando independencia respecto a la Gerencia de TI y una gestión objetiva de los riesgos.

7 POLÍTICAS

7.1 POLÍTICAS DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN

El Banco Pyme Ther S.A. delega a la Gerencia de Seguridad de la Información la gestión integral del SGSI, debiendo ésta recomendar los controles y mitigaciones necesarios, reportando directamente al Directorio de la institución para garantizar independencia y objetividad.

La seguridad de la información se precautela a través de compromisos contractuales con los empleados, proveedores y la difusión y cumplimiento de estas políticas. Las responsabilidades sobre seguridad de la información están

incorporadas en los Manuales de Funciones de todos los cargos del Área de TI y demás áreas de la organización.

El Banco Pyme Ther S.A. utiliza el estándar ISO/IEC 27001 como marco principal para la Gestión de Seguridad de la Información, complementado con NIST CSF 2.0, CIS Controls v8 y COBIT 2019, en cumplimiento permanente de la normativa y legislación vigentes de la ASFI.

La implementación del SGSI contempla los objetivos estratégicos de seguridad definidos en el PESI: Gobernanza del SGSI (OESI-1), Protección de Activos Críticos (OESI-2), Resiliencia y Ciberdefensa (OESI-3), Gestión de Identidades (OESI-4) y Cumplimiento Normativo (OESI-5).

7.2 PLANIFICACIÓN ESTRATÉGICA Y ORGANIZACIÓN DE LOS RECURSOS DE TECNOLOGÍAS DE LA INFORMACIÓN

El banco determina el Plan Estratégico de Tecnología de la Información (PETI 2026–2028), alineado al Plan Estratégico Institucional y a la estrategia de seguridad de la información, ejecutado a través de la Gerencia de TI y sus cuatro Subgerencias: Infraestructura y Telecomunicaciones, Desarrollo de Sistemas, Aseguramiento de Calidad, Operaciones y Soporte, más la Unidad de Administración de Datos.

La MAE delega al Gerente de TI el seguimiento a las tendencias tecnológicas, la gestión de los recursos de TI y el cumplimiento normativo, en coordinación permanente con la Gerencia de Seguridad de la Información. El Directorio ejerce la supervisión estratégica como máxima instancia de aprobación.

El Comité de Tecnología de la Información es la instancia responsable del seguimiento y control a los requerimientos tecnológicos y a la ejecución del

PETI, incluyendo las iniciativas: gobierno de TI (OETI-1), resiliencia de infraestructura (OETI-2), desarrollo ágil y seguro (OETI-3), certificación de calidad (OETI-4) y gestión de datos (OETI-5).

7.3 SEGURIDAD DE LA INFORMACIÓN FÍSICA Y LÓGICA

El banco define sus controles de seguridad a partir de la identificación y clasificación de activos de información, considerando su impacto en la confidencialidad, integridad y disponibilidad. La información se clasifica en:

1. Confidencial o crítica
2. Uso interno o privado
3. Uso público

Se establecen lineamientos para su manejo, almacenamiento, cifrado, difusión y eliminación segura. El acceso a la información se rige por el principio de menor privilegio, y cualquier intercambio con terceros requiere acuerdos formales de confidencialidad.

7.4 POLÍTICAS DE ADMINISTRACIÓN DE USUARIOS Y ACCESOS

El acceso a los sistemas se asigna según funciones y bajo los principios de menor privilegio y segregación de funciones. Cada usuario es responsable del uso adecuado de sus credenciales. No está permitido compartir contraseñas ni utilizar accesos de terceros. Se establece el uso obligatorio de autenticación multifactor (MFA) para accesos remotos y sistemas críticos. Asimismo, las contraseñas deben cumplir criterios de seguridad definidos y renovarse periódicamente.

7.5 POLÍTICAS DE SEGURIDAD EN SERVICIOS DE COMPUTACIÓN EN LA NUBE

El banco define los criterios de seguridad para la gestión, tratamiento y protección de la información en servicios de computación en la nube, considerando ISO 27001, ISO 27018 y la normativa ASFI vigente. Los servicios cloud adoptados deberán cumplir con los más altos estándares de seguridad y protección de datos personales. Los servicios cloud para procesos core contarán con un proyecto de implementación formal, con evaluación de riesgos de seguridad previa. Para procesos de soporte, los resultados de la evaluación quedarán documentados y disponibles a requerimiento de la MAE o el regulador ASFI.

Se establece que los proveedores de servicios de computación en la nube deberán cumplir al menos los siguientes criterios:

- a) Los datos personales solo podrán ser tratados de acuerdo con los requisitos definidos por el banco.
- b) El proveedor aceptará evaluaciones periódicas de sus servicios, proporcionando soporte y documentación necesaria.
- c) El proveedor brindará herramientas respetando los derechos de acceso, rectificación, cancelación y oposición.
- d) Las brechas de seguridad serán documentadas y reportadas oportunamente al banco.
- e) La publicación de datos solo puede realizarse bajo obligación legal, informando al banco antes de cumplirla.
- f) El proveedor cumplirá la legislación boliviana vigente y la normativa de la ASFI.

7.6 POLÍTICAS DE SEGURIDAD FÍSICA DE LOS ACTIVOS DE INFORMACIÓN

El banco establece controles de seguridad física para proteger el acceso a las áreas de exclusión, incluyendo el Centro de Procesamiento de Datos (CPD) de la Sede Central en La Paz, las salas de telecomunicaciones y demás áreas donde se genera, procesa o almacena información institucional. La Subgerencia de Infraestructura y Telecomunicaciones, a través del Encargado de Seguridad Física y CPD, lidera la ejecución de la iniciativa INF-1 del PETI (Optimización del CPD).

Se establecen límites de acceso de acuerdo con la zonificación definida según la clasificación de la información y las funciones del personal autorizado. El acceso está determinado en la Matriz de Acceso Físico, la cual es revisada y actualizada periódicamente por la Gerencia de Seguridad de la Información. El banco define e implementa parámetros y procedimientos para detectar posibles brechas de seguridad física y ejercer acciones correctivas oportunas. Se implementan controles para proteger los activos de amenazas físicas y ambientales, incluyendo sistemas de monitoreo, control de acceso con identificación biométrica o tarjeta, y protección contra incendio, inundación y otras contingencias en el CPD.

7.7 POLÍTICAS DE GESTIÓN DE INCIDENTES DE SEGURIDAD

El banco establece un proceso formal de gestión de incidentes de seguridad coordinado por la Gerencia de Seguridad de la Información, orientado a detectar, contener y resolver incidentes de manera oportuna, siguiendo las fases: Detección, Contención, Erradicación y Recuperación.

Todo incidente debe ser reportado de inmediato a la Gerencia de Seguridad de la Información. Los incidentes críticos serán escalados al Directorio y a la Gerencia General, y comunicados al regulador ASFI cuando corresponda. La meta del PESI establece que el 95% de los incidentes críticos sean contenidos en menos de 4 horas al tercer año.

El software de monitoreo y logs (SIEM: Splunk/ELK) y las herramientas EDR son los pilares tecnológicos para la detección temprana de intrusiones, según la iniciativa I4.2 del PEI (Despliegue de EDR). Los incidentes serán registrados y analizados para incorporar lecciones aprendidas en la mejora continua del SGSI. Se realizarán pruebas de penetración periódicas coordinadas por la Gerencia de Seguridad de la Información.

7.8 POLÍTICAS DE CONTINUIDAD DEL NEGOCIO Y RECUPERACIÓN ANTE DESASTRES

Los sistemas críticos, incluyendo el Core Bancario y los canales digitales (Banca Web y Aplicación Móvil), deben mantener una disponibilidad mínima del 99.5% al cierre del primer año, con meta progresiva hacia el 99.9% al tercer año, con ventanas de mantenimiento programadas de 01:00 a 04:00 AM para minimizar el impacto a los clientes.

Se definen los siguientes objetivos de recuperación para sistemas críticos, a ser verificados mediante simulacros semestrales de Disaster Recovery:

- a) RTO (Recovery Time Objective): menor a 8 horas en el Año 1, menor a 6 horas en el Año 2, y menor a 4 horas en el Año 3.
- b) RPO (Recovery Point Objective): alineado a la política de backups periódicos, con replicación de datos gestionada por el Operador de Backup y Continuidad.

El Plan de Recuperación ante Desastres (DRP) será documentado, mantenido actualizado y probado regularmente mediante simulacros semestrales coordinados por la Gerencia de Seguridad de la Información y la Subgerencia de Operaciones y Soporte. Los respaldos periódicos de bases de datos financieras (Oracle/SQL Server en la SAN) y sistemas críticos son obligatorios, administrados a través del Sistema de Backups y Recuperación (OPS-2 del PETI).

7.9 POLÍTICAS DE DESARROLLO SEGURO DE SOFTWARE

Todo desarrollo de software del banco, incluyendo la Banca Web, la Aplicación Móvil y las APIs de integración del Core Bancario, incorporará controles de seguridad desde las etapas tempranas del ciclo de desarrollo, siguiendo el estándar OWASP Top 10 2021 y los lineamientos del objetivo OETI-3 del PETI (Desarrollo Ágil y Seguro).

La Subgerencia de Desarrollo de Sistemas aplicará metodologías ágiles incorporando revisiones de seguridad en cada ciclo de entrega. El Encargado de QA y el Encargado de Certificación verificarán el cumplimiento de los estándares de seguridad y funcionalidad antes de aceptar cada entregable, conforme a las iniciativas QA-1 y QA-2 del PETI. La meta es que el 80% de los proyectos de software cuenten con certificación de QA al tercer año (OEI-5 del PEI). Toda aplicación debe someterse a pruebas de seguridad antes de pasar a producción, incluyendo revisión de código estático, pruebas de vulnerabilidades dinámicas y evaluación de componentes de terceros. Los componentes y librerías de terceros serán evaluados y mantenidos actualizados. La iniciativa SI-2 del PESI (Ciclo de Vida de Desarrollo Seguro) se ejecuta en coordinación

entre la Gerencia de Seguridad de la Información y la Subgerencia de Aseguramiento de Calidad.

8 INCUMPLIMIENTOS

El incumplimiento de estas políticas será sancionado conforme al Reglamento Interno de Trabajo, sin perjuicio de responsabilidades legales adicionales. Los casos graves podrán ser escalados al Directorio y a la ASFI.

9 APROBACIÓN

El presente documento ha sido elaborado por la Gerencia de Seguridad de la Información del Banco Pyme Ther S.A. y revisado por la Gerencia de TI y la Auditoría Interna. Ha sido aprobado por las instancias correspondientes, momento a partir del cual es puesto en vigencia y a disposición del personal dependiente del Banco Pyme Ther S.A.

Elaborado por	Revisado por	Aprobado por
Gerencia de Seguridad de la Información	Gerencia de TI / Auditoría Interna	Gerente General / Directorio
Fecha: 06/04/2026	Fecha: 06/04/2026	Fecha: 06/04/2026